

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

Annexure A

MOCK INTERVIEW

Code of Conduct:

I Challa Priyadarshini(192311118) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Ch Priyadarshini

ANNEXURE A MOCK INTERVIEW

SSL/TLS, Secure Payments, Malware, Firewalls and IDS/IPS

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.

SSL (Secure Sockets Layer) is the predecessor of TLS and is now obsolete. SSL 2.0 and SSL 3.0 contain design weaknesses and are vulnerable to attacks such as downgrade attacks and protocol-level exploits. SSL 3.0 was especially affected by the POODLE attack, which can expose information when CBC-mode encryption is used under certain conditions. SSL also lacks the modern cryptographic design, stronger cipher suites, and protocol improvements expected in current secure communications. TLS improves security through stronger cipher-suite design, authenticated key exchange, better integrity protection, secure protocol negotiation, and removal of obsolete algorithms. Modern systems should disable SSL and old TLS versions and use current TLS configurations.

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

In a simplified TLS 1.3 handshake, the client sends a ClientHello containing supported protocol parameters and a key-share. The server replies with a ServerHello, selects compatible parameters, provides its own key-share, and sends a certificate and authentication information. The client validates the certificate and both sides use the ephemeral key shares to derive a shared secret. A key-derivation process then creates symmetric traffic keys. After the handshake is authenticated, application data is encrypted using efficient symmetric cryptography. The important idea is that the public-key/key-exchange phase establishes shared secrets, while symmetric session keys protect the actual data.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

Both SSL and TLS use asymmetric cryptography or key exchange to establish shared secrets and symmetric encryption for application data. However, TLS progressively replaced weak algorithms and improved authentication, key derivation, integrity protection, and handshake design. TLS 1.2 supports strong cipher suites such as AES-GCM and modern key exchange mechanisms, while TLS 1.3 removes many legacy algorithms and simplifies the handshake. TLS 1.3 also provides forward secrecy through ephemeral key exchange and reduces handshake latency. Therefore, TLS is not simply a renamed SSL; it represents a significant security and protocol redesign.

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

Suppose a banking application accepts any certificate presented by a server without checking whether it is trusted, valid for the requested hostname, and within its validity period. An attacker positioned between the client and the legitimate bank could present a fraudulent certificate. If the application accepts it, the attacker may establish encrypted connections with both sides and relay traffic while reading or modifying information. Credentials, session cookies, payment details, or sensitive requests could be exposed. Proper validation must check the certificate chain, trusted root, hostname, validity period, key usage, and relevant revocation or policy requirements. Encryption without authentication does not provide trustworthy communication.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

A digital certificate binds a public key to an identity such as a domain name. It is digitally signed by a certificate authority (CA), allowing a client to verify that the certificate was issued within a trusted PKI

hierarchy. During a TLS connection, the server proves possession of the corresponding private key. The client also verifies certificate details such as the hostname and validity. This prevents an attacker from simply claiming to be the legitimate server. Certificates therefore provide server authentication and support trust establishment, while the TLS handshake uses the authenticated identity to establish secure session keys.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

Secure Electronic Transaction (SET) was designed specifically for card payments over the Internet. It used digital certificates to authenticate participants such as cardholders and merchants and employed cryptography to protect transaction information. A key concept was separation of order information from payment information so that a merchant did not need to receive the complete card details. SET used digital signatures and encryption to provide confidentiality, integrity, authentication, and non-repudiation. In a typical transaction, the customer, merchant, and payment gateway participate in a structured cryptographic exchange. Although technically strong, SET was complex and required specialized infrastructure and software.

7. Evaluate the limitations of the SET protocol in current online payment systems.

SET is rarely used in modern consumer payment systems because it introduced significant operational complexity. Users and merchants needed certificates and supporting software, while payment gateways and banks needed compatible infrastructure. Certificate management and the protocol's detailed transaction flow increased deployment and maintenance costs. User experience was also less convenient than today's browser- and app-based payment methods. Modern systems typically use TLS to protect communication and rely on payment networks, tokenization, secure APIs, 3-D Secure, and other mechanisms for payment authentication. Thus, SET demonstrated strong security concepts but was difficult to deploy at Internet scale.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

SET was a dedicated payment protocol designed to secure card transactions end-to-end with certificates, encryption, and digital signatures. TLS is a general transport security protocol that protects communication between applications and servers. Modern payment systems generally combine TLS with payment-specific controls rather than using SET. TLS is more practical because it is widely supported by browsers, mobile platforms, APIs, cloud services, and payment gateways. It also offers strong modern versions such as TLS 1.3 and can be combined with tokenization, strong customer authentication, fraud detection, and secure payment APIs. Therefore, TLS-based architectures are more scalable, interoperable, and user-friendly today.

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

Consider a company where an employee installs a seemingly legitimate free utility from an untrusted source. The program secretly opens a backdoor and steals credentials but does not automatically copy itself to other systems. This behavior is characteristic of a Trojan because the malware disguises itself as legitimate software and depends on the victim executing it. A virus normally attaches itself to a host file or program and spreads when the infected host is executed or shared. A worm is self-propagating and can spread across networks without requiring a user to attach it to another file. The propagation mechanism is therefore the key distinction.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

First, isolate affected systems and segment the network to stop lateral movement. Block known malicious traffic and vulnerable services at firewalls and network controls. Patch the exploited operating-system or application vulnerability and disable unnecessary services. Use endpoint detection

and response to identify infected hosts and remove the malware. Reset compromised credentials and investigate suspicious authentication activity. Network monitoring, IDS/IPS alerts, email filtering, application allow-listing, regular backups, and employee awareness further reduce risk. After containment, restore systems from trusted sources and perform a root-cause review so that the same vulnerability cannot be exploited again.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

A Trojan can seriously affect both confidentiality and integrity because it may provide attackers with remote access. For example, a user downloads a fake document viewer that secretly installs a remote-access Trojan. The attacker can capture credentials, read confidential files, monitor activity, alter documents, install additional malware, or use the machine as a launching point for attacks. Confidentiality is harmed when information is stolen, while integrity is harmed when files, configurations, or transactions are modified without authorization. Strong application controls, endpoint security, least privilege, software updates, and user awareness are important defenses.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

Viruses generally require a host file or program and spread when the infected host is executed or shared. Their impact can include corrupted files, altered programs, data loss, and system instability. Worms are self-propagating and commonly exploit vulnerabilities or weak credentials to move between networked systems, making them particularly dangerous for rapid outbreaks and network congestion. Trojans do not primarily rely on self-replication; instead, they trick users into installing or executing malicious software. Their impact often includes credential theft, surveillance, unauthorized access, and installation of additional malware. The most important difference is how each malware type reaches the next victim.

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

A packet-filtering firewall examines network packets using attributes such as source and destination IP addresses, ports, and protocol type. Rules determine whether a packet is allowed or denied. For example, a rule may allow HTTPS traffic to a public web server while blocking unsolicited inbound connections to internal hosts. Packet filtering is fast and simple, but basic stateless filtering does not understand application content or connection context. It can also be difficult to manage large rule sets. Modern encrypted traffic, cloud architectures, mobile users, application-layer attacks, and sophisticated threats require additional controls such as stateful inspection, application-aware firewalls, IDS/IPS, endpoint protection, and zero-trust access controls.

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

Suppose an enterprise hosts a public web server and an internal database. The firewall can allow inbound TCP 443 to the web server, allow administrative access only from an approved management network, and deny direct inbound database access from the Internet. Outbound traffic can be restricted to required destinations and protocols. A simple policy is: allow established/related traffic; allow HTTPS to the public web server; allow SSH or remote administration only from the management subnet; deny Internet access to database ports; and deny all other unsolicited inbound traffic. Logging denied connections helps detect scanning and policy violations. Rules should follow least privilege and be reviewed regularly.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

A stateless firewall evaluates each packet independently according to configured rules. A stateful firewall maintains a connection table and understands whether packets belong to an established session. This allows it to permit return traffic for legitimate connections without creating broad inbound rules. Stateful inspection generally provides stronger security and simpler rule management for conventional network traffic. However, stateful firewalls still cannot detect every application-level attack and may

not be sufficient for encrypted or highly distributed environments. Therefore, stateful inspection is a major improvement over basic stateless filtering, but it should be combined with application-aware and endpoint security controls.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

Packet-filtering firewalls provide basic IP/port filtering. Stateful firewalls add connection awareness. Proxy or application-level firewalls inspect traffic at the application layer. Next-generation firewalls (NGFWs) combine stateful inspection with application awareness, intrusion prevention, identity controls, URL or content filtering, and other advanced features. Web application firewalls specialize in protecting HTTP/HTTPS applications from attacks such as injection and malicious requests. For a modern enterprise, an NGFW is generally the most suitable core perimeter control because it provides deeper visibility and policy enforcement. It should be complemented by segmentation, endpoint protection, WAFs for public applications, and secure remote-access controls.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

Signature-based IDS detection compares observed traffic or events with known attack patterns. It is highly effective for known threats and usually produces understandable alerts, but it can miss new or modified attacks for which no signature exists. Anomaly-based detection establishes a model of normal behavior and flags significant deviations, such as an unusual traffic spike, unexpected protocol use, or abnormal login activity. It can detect previously unknown threats but may generate more false positives. Modern IDS deployments often combine both methods with threat intelligence, behavioral analytics, and contextual information to improve detection quality.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

An IDS can identify DDoS indicators such as sudden traffic-volume increases, repeated requests from many sources, protocol anomalies, and unusual connection rates. An IPS can automatically block or rate-limit matching traffic when confident rules identify malicious patterns. However, large volumetric DDoS attacks can overwhelm the Internet link before an on-premises IPS can react. Effective defense therefore uses layered controls: upstream DDoS protection, traffic scrubbing or CDN services, rate limiting, network ACLs, load balancing, resilient architecture, and continuous monitoring. IDS/IPS contributes detection and enforcement but should not be considered the only DDoS defense.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

An Intrusion Detection System (IDS) primarily monitors traffic or host events and generates alerts when suspicious activity is detected. It is generally deployed out of band or in a monitoring position, so it does not necessarily block the attack. An Intrusion Prevention System (IPS) is placed inline and can actively block, reset, drop, or otherwise prevent traffic according to security rules. IDS is useful when visibility and low risk of disrupting legitimate traffic are priorities. IPS provides faster automated response but must be carefully tuned because an incorrect blocking rule can interrupt legitimate business traffic. Many organizations use both.

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

False positives can be reduced through careful baseline creation, environment-specific tuning, asset classification, and rule prioritization. Administrators should disable irrelevant signatures, adjust thresholds, and whitelist trusted behavior only when justified. Correlating IDS alerts with identity, endpoint, vulnerability, DNS, and firewall data can provide context and reduce unnecessary alerts. Machine-learning or behavioral methods should be trained using representative organizational traffic and continuously validated. Regular review of alerts, feedback from incident responders, and measurement using precision, recall, and false-positive rates help maintain accuracy. The objective is not to eliminate alerts, but to make high-risk alerts reliable and actionable.

Conclusion

The 20 questions collectively show that effective cybersecurity depends on layered controls rather than a single technology. Modern TLS provides authenticated and encrypted communication, while certificates establish server identity. SET illustrates the value of specialized payment security but also demonstrates the importance of scalability and usability. Malware defenses must address propagation, vulnerabilities, user behavior, and endpoint compromise. Firewalls enforce network policy, while IDS and IPS provide visibility and automated threat response. In an enterprise, these technologies should operate together with patch management, least privilege, network segmentation, monitoring, backups, incident response, and continuous security improvement.